

Laboratorio 08 - VulnerableWordpress + WPScan en AWS

Curso: ITI-724 PRINCIPIOS DE SEGURIDAD DE TI Profesor: Roberto Escobar

Modalidad: Individual

Objetivos de la Práctica.

Analizar vulnerabilidades en aplicaciones web, utilizando un CMS ampliamente difundido como caso de estudio, para la comprensión de su impacto y fortalecer la seguridad en entornos organizacionales.

Instrucciones: Con la ayuda del profesor en clases, atienda los siguientes ejercicios. Recuerde tomar pantallazos de cada paso que realiza y colocar la evidencia en cada sección correspondiente.

Análisis de Impacto:

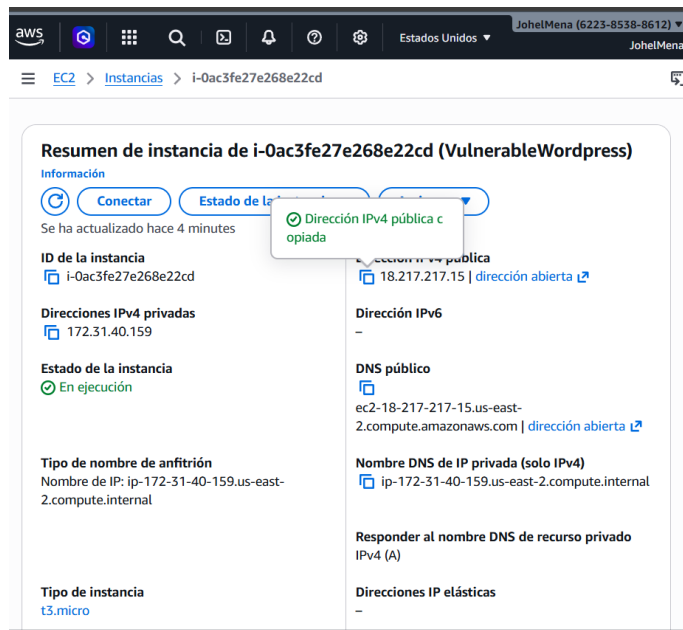
[https://colorlib.com/wp/cms-market-share/#:~:text=Key%20CMS%20Market%20Share%20Statistics%20\(March%202026\),discovered%20in%202025%20%E2%80%94%20up%2042%25%20\(Patchstack\)](https://colorlib.com/wp/cms-market-share/#:~:text=Key%20CMS%20Market%20Share%20Statistics%20(March%202026),discovered%20in%202025%20%E2%80%94%20up%2042%25%20(Patchstack))

<https://apexdigital.ro/blog/wordpress-in-2026/#:~:text=most%20business%20websites.-,43.5%25%20Of%20all%20websites,website%20builders%20and%20CMS%20platforms.>

Instalación de VulnerableWordpress

1. Lance una nueva instancia de Amazon AWS con nombre: **VulnerableWordpress**, conéctese por medio de Putty y actualice Ubuntu:

```
sudo apt update
```



```
ubuntu@ip-172-31-40-159:~$ sudo apt update
Hit:1 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy InRelease
Get:2 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy-updates InRelease [128 B]
Get:3 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy-backports InRelease [128 B]
Get:4 http://security.ubuntu.com/ubuntu jammy-security InRelease [129 kB]
Get:5 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy/universe amd64 Packages [128 B]
Get:6 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy/universe Translation-en [128 B]
Get:7 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy/universe amd64 c-n-f Metadata [128 B]
Get:8 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy/multiverse amd64 Packages [128 B]
Get:9 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy/multiverse Translation-en [128 B]
```

2. Instale Docker en la instancia

```
sudo apt install docker.io -y
```

3. Ahora habilite y arranque el servicio de Docker:

```
sudo systemctl enable --now docker
```

4. Verifique que Docker esté funcionando correctamente:

```
sudo docker run hello-world
```

Deberías ver un mensaje que incluye algo como:

"Hello from Docker!"

```

No user sessions are running outdated binaries.

No VM guests are running outdated hypervisor (qemu) binaries on this host.
ubuntu@ip-172-31-40-159:~$ sudo systemctl enable --now docker
ubuntu@ip-172-31-40-159:~$ sudo docker run hello-world
Unable to find image 'hello-world:latest' locally
latest: Pulling from library/hello-world
4f55086f7dd0: Pull complete
d5e71e642bf5: Download complete
Digest: sha256:452a468a4bf985040037cb6d5392410206e47db9bf5b7278d281f94d1c2d0931
Status: Downloaded newer image for hello-world:latest

Hello from Docker!
This message shows that your installation appears to be working correctly.

```

5. Ejecutar un WordPress vulnerable listo:

```
sudo docker run -d -p 8080:80 eystsen/vulnerablewordpress
```

```

ubuntu@ip-172-31-40-159:~$ sudo docker run -d -p 8080:80 eystsen/vulnerablewordpress
Unable to find image 'eystsen/vulnerablewordpress:latest' locally
latest: Pulling from eystsen/vulnerablewordpress
e1eabe0537eb: Pull complete
cc5307a2344f: Pull complete
4701f1215c13: Pull complete
8c4be94fc51c: Pull complete
a7344f52cb74: Pull complete
856e81c2a653: Pull complete
515c9bb51536: Pull complete
346069c57e29: Pull complete
a883b6fbb903: Pull complete
91e0525e7b9b: Pull complete
e036ed0e0f5a: Pull complete
77adf381c254: Pull complete
bd5ca70b381f: Pull complete
2849d64386d3: Pull complete
bb1c36bd1036: Pull complete
691140c0238f: Pull complete
1deb73b392d8: Pull complete
24a145947f1b: Pull complete
0767cadb7fd7: Pull complete
72076e14a646: Pull complete
d62502aaab81: Pull complete
7582fe4962e8: Pull complete
761db0eeaa81: Pull complete
1b7ffb85ca2f: Pull complete
a3915ee459e0: Pull complete
88ba0b9e5048: Pull complete
a8ed753a308d: Pull complete
02e7fd67256c: Pull complete
c51720b64e9b: Pull complete
Digest: sha256:4f9d0b34ce3f38fb5bed965879fe9f02f179706e97fdc3f3b619eb2df86f2950
Status: Downloaded newer image for eystsen/vulnerablewordpress:latest
5aabdb8b6b1688ee1d1397ded85418373c61c4f30f776c89c906bd74fef415b76
ubuntu@ip-172-31-40-159:~$ █

```

6. Antes de probar en el navegador debes asegurarte de que el Security Group de tu instancia permita el puerto 8080.

7. Luego, abre en el navegador: http://IP_PUBLICA:8080 y confirma que carga WordPress.

```

5aabd8b6b1688ee1d1397ded85418373c61c4f30f776c89c906bd74fef415b76
ubuntu@ip-172-31-40-159:~$ sudo docker ps
CONTAINER ID   IMAGE                                COMMAND                  CREATED
PORTS         NAMES
5aabd8b6b168   eystsen/vulnerablewordpress        "/bin/bash /start.sh"   2 minutes ago
3306/tcp, 0.0.0.0:8080->80/tcp, [::]:8080->80/tcp  youthful_chandrasekhar
ubuntu@ip-172-31-40-159:~$ █

```

Welcome

Welcome to the famous five-minute WordPress installation process! Just fill in the information below and you'll be on your way to using the most extendable and powerful personal publishing platform in the world.

Information needed

Please provide the following information. Don't worry, you can always change these settings later.

Site Title

Username

Usernames can have only alphanumeric characters, spaces, underscores, hyphens, periods, and the @ symbol.

Password, twice

A password will be automatically generated for you if you leave this blank.

- Realiza las configuraciones finales de Wordpress. Así, el sitio web vulnerable de Wordpress quedaría listo.

Site Title: Prueba Wordpress

Username: admin

Password: Seguridad2026.

Site Title

Prueba Wordpress

Username

admin

Username can have only alphanumeric characters, spaces, underscores, hyphens, periods, and the @ symbol.

Password, twice

A password will be automatically generated for you if you leave this blank.

.....

Strong

Hint: The password should be at least seven characters long. To make it stronger, use upper and lower case letters, numbers, and symbols like ! " ? \$ % ^ &).

Instalación de WPScan

1. Lance una nueva instancia de Amazon AWS con nombre: **WPScan**, conéctese por medio de Putty y actualice Ubuntu

Resumen de instancia de i-0b5909e13348b0d52 (WPScan) Información

Conectar
Estado de la instancia ▼
Acciones ▼

Se ha actualizado hace less than a minute

ID de la instancia i-0b5909e13348b0d52	Dirección IPv4 pública 18.219.223.180 dirección abierta
Direcciones IPv4 privadas 172.31.42.30	Dirección IPv6 -
Estado de la instancia En ejecución	DNS público ec2-18-219-223-180.us-east-2.compute.amazonaws.com dirección abierta
Tipo de nombre de anfitrión Nombre de IP: ip-172-31-42-30.us-east-2.compute.internal	Nombre DNS de IP privada (solo IPv4) ip-172-31-42-30.us-east-2.compute.internal
	Responder al nombre DNS de recurso privado IPv4 (A)

sudo apt update

```

ubuntu@ip-172-31-42-30:~$ sudo apt update
Hit:1 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy InRelease
Get:2 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy-updates InRelease [12
8 kB]
Get:3 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy-backports InRelease [
127 kB]
Get:4 http://security.ubuntu.com/ubuntu jammy-security InRelease [129 kB]
Get:5 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy/universe amd64 Packag
es [14.1 MB]
Get:6 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy/universe Translation-
en [5652 kB]
Get:7 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy/universe amd64 c-n-f
Metadata [286 kB]
Get:8 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy/multiverse amd64 Pack
ages [217 kB]
Get:9 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy/multiverse Translatio
n-en [112 kB]
Get:10 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy/multiverse amd64 c-r
-f Metadata [8372 B]
Get:11 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy-updates/main amd64 B

```

- Ahora instala las dependencias necesarias (Ruby y librerías de compilación):

sudo apt install ruby-full build-essential libcurl4-openssl-dev -y

5. Ve a este sitio y crea una cuenta gratuita:
<https://wpscan.com/register>

6. Luego Inicia sesión, ve a tu perfil, copia tu API Token

7. Primero, ejecuta el escaneo **sin** token. Ejecuta este comando (reemplaza tu dominio):

```
wpscan --url https://tusitio.com

[!] http://18.217.217.15:8080/wp-config.php.save
| Found By: Direct Access (Aggressive Detection)

[!] http://18.217.217.15:8080/wp-config.php~
| Found By: Direct Access (Aggressive Detection)

[!] http://18.217.217.15:8080/wp-config.txt
| Found By: Direct Access (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Fri Apr 10 03:43:31 2026
[+] Requests Done: 193
[+] Cached Requests: 6
[+] Data Sent: 48.29 KB
[+] Data Received: 23.348 MB
[+] Memory used: 294.082 MB
[+] Elapsed time: 00:00:04
ubuntu@ip-172-31-42-30:~$
```

8. Luego, ejecuta el escaneo **con** el token. Ejecuta este comando (reemplaza tu dominio y el token):

```
wpscan -url https://tusitio.com --api-token
```



```

[!] http://18.217.217.15:8080/wp-config.php.save
| Found By: Direct Access (Aggressive Detection)

[!] http://18.217.217.15:8080/wp-config.php~
| Found By: Direct Access (Aggressive Detection)

[!] http://18.217.217.15:8080/wp-config.txt
| Found By: Direct Access (Aggressive Detection)

[+] WPScan DB API OK
| Plan: free
| Requests Done (during the scan): 2
| Requests Remaining: 23

[+] Finished: Fri Apr 10 03:46:37 2026
[+] Requests Done: 143
[+] Cached Requests: 44
[+] Data Sent: 37.157 KB
[+] Data Received: 94.622 KB
[+] Memory used: 252.695 MB
[+] Elapsed time: 00:00:05
ubuntu@ip-172-31-42-30:~$

```

9. Complete el siguiente recuadro con la información de al menos tres vulnerabilidades encontradas:

# CVE de la vulnerabilidad	Análisis individual de la vulnerabilidad	Propuesta para mitigarlo
CVE-2015-5622 / CVE-2015-5623	Esta vulnerabilidad permite que un usuario autenticado inserte código malicioso (scripts) dentro del sitio web. Dicho código se almacena en la base de datos y se ejecuta cada vez que otro usuario accede a la página afectada. Esto puede comprometer sesiones de usuarios, robar cookies o redirigir a sitios maliciosos.	Actualizar WordPress a una versión superior a la 4.2.3, además de implementar validación y sanitización de entradas para evitar la ejecución de scripts maliciosos.
CVE-2015-2213	Esta vulnerabilidad permite a un atacante manipular consultas SQL mediante la entrada de datos maliciosos. Esto puede resultar en acceso no autorizado a la base de datos, extracción de información sensible o modificación de datos.	Actualizar WordPress a una versión segura (posterior a 4.2.4) y utilizar consultas preparadas (prepared statements) para evitar la inyección SQL.
CVE-2016-2222	Permite a un atacante forzar al servidor a realizar solicitudes HTTP hacia recursos internos o externos. Esto puede ser utilizado para escanear la red interna o acceder a servicios que no deberían estar expuestos.	Actualizar WordPress a una versión superior a 4.4.2 y restringir las solicitudes salientes del servidor mediante firewall o configuraciones de red.

Nota: Entregue este documento con las evidencias de cada paso en el espacio adecuado en el Campus Virtual.